LOT DE TRAVAIL 16

Droits, authentification et durcissement

Jalon M6 / durcissement | terminé | 2026-11-09

Résumé

Une table de droits unique (rôle × page × action) est partagée par l'API et le web. Un test parcourt les 33 routes de l'application pour les 4 rôles. Pendant ce travail, un défaut réel a été trouvé et corrigé : deux routes d'administration répondaient à tout le monde, même sans connexion (sources en §6).

1. Contexte et problématique

Avant ce lot, seul le rôle « interne » était restreint côté web, alors que la matrice canonique (`pre-dev/09-canonical-spec.md` §10) distingue quatre rôles. Un contrôle d'accès incomplet est une faute de sécurité clinique : l'administrateur ne doit pas voir les données patient, l'infirmier ne doit pas publier la configuration.

2. Objectifs

- Une seule source de vérité pour les droits, lue par l'API et par le web.
- Les pages manquantes de chaque rôle : journal d'audit, utilisateurs, notes et suivis, historique des références, historique du banc, pages « accès refusé » et « introuvable ».
- Un test qui échoue si une route est oubliée ou non protégée.

3. Démarche et méthode

Tâche T-w13 (droits et pages), puis T-w10 (durcissement). Les parcours Playwright, un par rôle, ont révélé le défaut décrit plus bas que les tests unitaires n'avaient pas vu.

4. Conception

ACTION	INFIRMIER	NÉPHROLOGUE	INTERNE	ADMIN
Capturer	oui	non	non	non
File et historique	oui (lecture)	oui	non	non
Notes, suivi, re-référence	non	oui	non	non
Banc	non	lecture	oui	non
Appareils	voir	voir	non	calibrer
Configuration clinique	non	publier	non	brouillon
Journal d'audit	non	oui	non	oui
Source : `docs/AUTHZ.md`, copie de la matrice canonique.				

5. Réalisation

- Table partagée dans `apps/api-nestjs/src/common/authorization.ts`, utilisée par le garde de rôles de l'API et par le garde de routes du web.
- Déconnexion, bandeau d'expiration de session, menu de profil, redirection vers l'accueil du rôle.
- Durcissement : limites de taille de corps (16 Mo, 50 éléments par lot de synchronisation) avec le corps d'erreur du contrat, test de charge à 4 envois parallèles, analyse des données personnelles dans le schéma, le contrat, les jeux de test, les corps d'erreur et les journaux (`docs/SECURITY.md`).

6. Vérification et résultats

VÉRIFICATION	RÉSULTAT	SOURCE
Matrice sur toutes les routes	33 routes × 4 rôles testées	`apps/api-nestjs/test/`, tâche T-w10
Suite API	143 passent, 0 échec, 8 ignorés	`pnpm --filter @dsfav/api test`, 2026-11-08
Parcours par rôle	4 sur 4 passent	Playwright `e2e/tests/roles.spec.ts`
Défaut trouvé	`GET /audit` et `GET /users` répondaient 200 sans jeton	observation du 2026-11-08, corrigée dans la foulée

7. Décisions et justifications

- La matrice canonique l'emporte sur le plan de travail : la page des notes est réservée au néphrologue, contrairement à ce que le plan prévoyait d'abord.
- Le défaut venait de contrôleurs qui déclaraient des rôles sans activer le garde ; le test qui parcourt toutes les routes empêche ce type d'oubli de revenir.
- Port de l'API fixé à 3101 (décision D-013) : le port 3001 est pris par un autre projet, ce qui avait fait échouer une connexion.

8. Limites et points ouverts

Aucune revue de sécurité externe ; pas de limitation de débit ni de verrouillage de compte ; les mots de passe de démonstration ne servent qu'au développement.

9. Ce qu'il faut retenir

- Un contrôle d'accès se teste route par route et rôle par rôle, pas en échantillon.
- Un test de parcours réel a trouvé ce que les tests unitaires ne voyaient pas.
- La règle de la spécification l'emporte sur l'idée du chef de projet.

10. Questions possibles du jury

- **Comment garantir qu'une nouvelle route est protégée ?** Le test parcourt toutes les routes de l'application et échoue si l'une répond sans jeton.
- **Pourquoi l'administrateur ne voit-il pas les patients ?** La matrice canonique lui réserve le parc d'appareils et la métrologie.
- **Y a-t-il des données personnelles ?** Non : seuls des pseudonymes existent, et un test le vérifie dans le schéma, le contrat, les fixtures et les journaux.

Références

`docs/AUTHZ.md` · `docs/SECURITY.md` · `docs/DECISIONS.md` (D-013) · `pre-dev/09-canonical-spec.md` §10